ACC-16 · Application Onboarding, SSO & SAML Claims Standard

What IT needs before an application is federated, which protocol it gets, the claim set every application receives — and how an application moves from one identity provider to another without breaking on the day.

Field	Value
Document ID	ACC-16
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	B. Account Usage
Operating tier	Tier 3 — Expert Services owns federation, claim configuration and the identity provider. Tier 4 approves every cutover of an application already in use. Tier 1 and Tier 2 do not configure federation, and should not be asked to.
Review cycle	Annually, and on any change of identity provider.
Relationship to ACC-08	This document governs how a PERSON signs in to an application. ACC-08 governs the non-human identity the application uses to act on the organization's behalf — the service account, the API credential, the SCIM bearer token. Most integrations need both, they are configured in the same hour by the same engineer, and that is precisely why they are written down separately.

1. Purpose

Picture two members of IT in a meeting called "saml claims", working out how one application should receive identity information from the organization. That is a perfectly reasonable way to configure one application. It is a poor way to configure thirty, because the next integration starts from the same blank page, reaches its own conclusions about which attribute should be the identifier, and nobody discovers the difference until an address changes or a vendor asks why two applications disagree about who somebody is.

Many organizations are also federating twice. When applications trust a legacy identity provider (Okta, Ping, or an on-premises federation server) and will eventually trust Entra ID, every claim decision made in one system has to be reproduced in the other. Decisions made from memory do not reproduce; decisions written down do.

This document does four things: it defines what IT needs from a department before an application can be onboarded at all, it fixes one claim standard for the whole estate, it states the two rules that cause the most damage when they are got wrong — the identifier and the group claim — and it defines how an application is migrated between identity providers with a rollback that actually works.

2. The intake — what IT needs before anything is configured

An application is not federated on the strength of an email saying that a vendor needs the metadata. The intake below is short, and every line of it exists because its absence has cost somebody something.

What IT needs	Why	Supplied by
A named business owner — a person, not a department	Somebody has to answer the access review (ACC-17), approve the claim set, decide who may use it, and be told when the vendor changes something. A department cannot do any of those.	The requesting department
The user population	Staff, contractors, temporary workers on second accounts, guests, or a named list. This determines the group strategy (§6), the provisioning model (§7) and the licence count.	The requesting department
The data classes the application will hold or receive	A claim is a disclosure. Sending an employee ID or a group membership to a third party is a data transfer, and the sensitive classes in M365-15 determine what is permitted.	Department, with IT
Licence model, cost, and who pays	Per-user licensing changes what the leaver process has to do and what a dormant account costs. Named-user licences that nobody reclaims are a standing bill (M365-20).	Department, with Finance
The contract, its term and its renewal date	The renewal date goes on the register (§10). An application nobody remembers renewing is an application nobody remembers reviewing.	The requesting department
A security review of the vendor	Before signature, not after. At minimum: where data is held, whether the vendor supports SAML or OIDC and SCIM, their breach-notification terms, and whether they support the authentication strength the organization requires (§9).	IT, with the department
Protocol and provisioning capability, in the vendor's own words	Vendors describe "SSO support" loosely. Ask for the specific standard, the metadata endpoint, whether they support signed assertions, and whether SCIM 2.0 is included in the purchased tier or is an upgrade.	The vendor, in writing
A test instance, or a documented way to test safely	Every rule in §8 assumes something can be tried before it is done to everybody.	The vendor

> **Two rules about the intake, stated because they will be tested**
>
> IT does not configure federation for an application with no named owner. Not as a favour, not for a pilot, and not "until we sort out who owns it". An unowned integration is an entitlement nobody will ever review and a vendor relationship nobody will ever end.
>
> The intake belongs before contract signature. In practice it usually arrives afterwards, when the department has already committed and the answer to "does it support SCIM?" is no. IT should still complete it — late intake is worth far more than none — and the register should record that the application was contracted before it was assessed, because that pattern is the finding, not the individual application.

3. Choosing the protocol

Option	Use when	What it gives the organization	Notes
SAML 2.0	The application is an established enterprise product whose federation support is SAML. Usually the most common answer today.	Central authentication, Conditional Access, MFA and authentication strength, and one sign-in log.	Claims per §4. Signed assertions. Certificate expiry is a diarised change under GOV-04.
OIDC / OAuth 2.0	The application is modern, or is a mobile or single-page application, or needs delegated access to Microsoft 365 data on a user's behalf.	The same, plus scoped API access and refresh-token control rather than a shared credential.	Prefer this for new integrations where the vendor supports both. Consent and permission scopes are a Tier 3 review, not a click-through.
SCIM 2.0	Alongside either of the above. SCIM is not a sign-in protocol — it is how accounts are created, updated and deactivated inside the application.	It is what makes ACC-01's leaver process actually reach the application (§7).	Requested at intake. Retrofitting it later means reconciling accounts that already exist.
Directory-integrated (LDAP / Kerberos)	A legacy on-premises application that cannot federate but can read the directory.	Central credentials, but not central policy — MFA and Conditional Access do not apply.	Treated as a transitional state with a stated end. Record the intended replacement on the register.
No federation — local credentials	The vendor genuinely supports nothing else, and the business need is real.	Nothing. This is the option the organization pays for in every other document.	Requires a Tier 4 decision and a named compensating control. See the callout below.

What a local-credential application actually costs the organization

It is chosen far more often than it should be, because the bill arrives somewhere else. Costed honestly:

The password is outside ACC-04, so the organization's standard and self-service reset do not apply and every reset becomes a ticket, on a desk where lockouts are already among the largest ticket categories. It also teaches users that some organization systems have their own password, which is the condition under which credential-harvesting messages succeed.

MFA is whatever the vendor offers, if anything, and it is invisible to ACC-03. The organization cannot state which multifactor system governs that application — exactly the question a managed security partner will ask, and one that often cannot be answered from any record.

The ACC-01 leaver procedure does not reach it. Disabling the organization account does nothing; access ends only when somebody remembers this application exists. And there is no sign-in log the organization can see, so GOV-03 cannot investigate it and ACC-17 cannot review it without asking the vendor for a list.

None of this makes a local-credential application forbidden. It makes it a decision with a price, taken at Tier 4, recorded on the register, with a named manual deprovisioning step on the ACC-01 checklist and a date at which federation is revisited.

4. The organization's claims standard

This is the centrepiece of the document. It exists so that the next "saml claims" meeting is a ten-minute confirmation against a table rather than a fresh derivation.

Every application receives the same core claim set unless it has a documented reason not to. Deviations are recorded on the register (§10) with the reason, so that a future engineer can tell a deliberate exception from an accident.

Claim	What it is for	Entra source attribute	Rule
NameID (Unique User Identifier)	The identifier the application keys the user record on. The single most consequential claim in the assertion.	user.objectid	Format persistent (urn:oasis:names:tc:SAML:2.0:nameid-format:persistent). NEVER an email address. See §5.
emailaddress	Display, notification and correspondence inside the application.	user.mail	Sent for display only. If the application keys on this, it is misconfigured (§5).
upn	The sign-in name, where the application shows or matches on it.	user.userprincipalname	Also mutable. Same caution as email — it changes when a name changes (M365-05, ACC-02).
givenname	First name.	user.givenname	Straightforward. Empty for some service and shared identities — test for it.
surname	Last name.	user.surname	As above.

Claim	What it is for	Entra source attribute	Rule
displayname / name	The name the application shows.	user.displayname	Send only if the application uses it. Do not send a claim nothing consumes.
employeeid / record ID	Matching a person to their record in a system of record — the HR and user system of record, a CRM, a line-of-business platform.	user.employeeid for staff. The attribute carrying any other record ID must be settled first — see the open item below.	Where an application needs to match a record in a system of record, this is the claim that does it, not the email address.
groups / roles	Authorisation — what the person may do inside the application.	user.groups (filtered) or user.assignedroles	Read §6 before configuring this one. The default configuration does not scale.
department, jobtitle	Only where the application does something with them.	user.department, user.jobtitle	Optional. Each is a disclosure of personal data to a third party (M365-15).

4.1 Rules that apply to every claim

- Claims are mapped from a source attribute. A value typed in by hand is a value that will be wrong for somebody, silently, forever. Anything the application does not consume is not sent — every claim leaves the tenant.
- Claim names are used exactly as the vendor's documentation specifies, including the full schema URI where one is required. A claim under a nearly-correct name is not an error — it is ignored, which is much harder to diagnose.
- Where a source attribute is empty for part of the population, the claim is empty for those people. Part-time staff, guests, temporary workers on second accounts (ACC-02, ACC-09) and service identities are the usual gaps.
- Test with a real account from every population that will use the application — never with the configuring engineer's own account, which is the least representative in the tenant: fully attributed, in every group, and usually privileged.
- The finished mapping is recorded on the worksheet at Appendix B and attached to the register entry. That worksheet is the artefact that is missing after a one-off claims meeting.

4.2 The OIDC equivalents

The same rules apply with different names, and the identifier rule is the one that translates least obviously. In an OpenID Connect token the durable identifiers are oid — the user's object ID in the tenant — and sub, which is stable but scoped to the individual application. Key on one of those. Do not key on email or preferred_username: both are mutable, and preferred_username is explicitly documented as not suitable as an identifier. given_name, family_name, roles and groups carry the rest, and the §6 size limits apply to a JWT as well as to an assertion.

Open — owner: Tier 3, before the next integration that needs a user identifier

Many organizations have no settled answer to which directory attribute carries a person's record ID from the system of record, and the next application that needs to match a user to their record will have to pick one under time pressure.

This is not a small housekeeping item. Directory extension attributes are finite and cannot be un-allocated once something depends on them — a dynamic group request can be declined because the attribute it needs has already been committed to the ticketing system (M365-21 §3).

ACTION: Tier 3 to determine which attribute holds that record ID today, record it in the attribute register (M365-04 §7), and raise a change under M365-21 if a new commitment is required. Until it is recorded, no application may be configured to consume it.

---

5. NameID — immutable, non-reassignable, and never an email address

The rule, and it is not a preference

NameID is the value the application uses to decide which existing user this is. It must be immutable — it never changes for a given person — and non-reassignable — it is never later given to somebody else.

An email address is neither. Changing an address is a routine, supported, correct workflow with its own procedure (M365-05).

So: NameID is user.objectid, in persistent format, on every new integration. No exceptions without a Tier 4 decision recorded on the register.

5.1 Why this is the rule that costs the most when it is broken

An address change is not exotic. Marriage, a legal name change, a correction to a misspelling made at hiring, a change of preferred name, a person moving between populations under ACC-02 — each produces a new primary address, and M365-05 exists to handle them properly. On an application keyed to the address, that routine change produces one of two failures, and both arrive at the desk days later as "I cannot get into X":

- The application does not recognise the new value, creates a brand-new empty account, and the person loses their history, their permissions, their saved work and their open items. Nothing indicates that the old record still exists.
- Or — worse — the address is later reassigned to a different person under the naming standard, and that person signs in to the first person's record, with their access and their data. This is the failure that is not merely inconvenient. Neither failure is visible in the identity provider. The sign-in succeeds. The assertion is correct. The damage is entirely inside the application, which is why it is found late and by the user.

5.2 Applications already keyed on email

Some are. The honest position is that most organizations do not know how many, and the first pass of the register (§10) is how that is established.

1. Identify them. For each federated application, record the NameID source attribute and format on the register. Where it is an email address or a UPN, flag it.
2. Add every flagged application to the M365-05 procedure as a named downstream dependency, so that an address change triggers a per-application remediation instead of a surprise. This is a small edit to M365-05 and it is the immediate mitigation.
3. Migrate the identifier at the next cutover (§8). That is the natural moment, because the trust relationship is being rebuilt anyway and the vendor is already engaged.
4. Be realistic about the cost. Changing the NameID on a live application means the vendor must re-map every existing user record from the old value to the new one. Some vendors do this on request, some charge for it, and some cannot do it at all — in which case the application stays flagged, permanently, and that fact belongs in the annual report to Tier 4 rather than in an engineer's memory.

---

6. Group and role claims, and the claim-size limit

Authorisation inside an application is driven either by group claims — the identity provider sends the groups the person is in, and the application maps them to its own roles — or by app roles, where the assignment is made in the identity provider and the application receives one or two role values. The choice matters more than it appears to.

> **The failure nobody predicts: the claim-size limit**
>
> Sending "all groups" is the default configuration and the one most vendors ask for. It works in testing, because the engineer testing it is in a manageable number of groups, and it fails later for the users who are in the most.
>
> Microsoft's documented behaviour is that when a user is a member of more than 150 groups for a SAML assertion, or more than 200 for a JWT, the groups claim is not emitted at all. In its place the token carries a link to a Microsoft Graph endpoint from which the application is expected to retrieve the list. Most applications do not implement that link.
>
> The result is the most confusing of all authorisation failures: the sign-in succeeds, the user arrives, and the application shows them nothing, because as far as it can tell they are in no groups and so have no role. It affects only some users — usually the longest-serving and most senior — which makes it look like a personal account problem rather than a design problem. Large tokens also hit HTTP header size limits at the application or its proxy, producing an opaque failure at the redirect that looks like a broken link.
>
> And the group count grows without anybody deciding to grow it: dynamic groups (M365-04) add members by rule, so a user's count rises as the organization adds groups, not as the user does anything.

Strategy	How it works	Assessment
App roles (preferred)	Roles are defined on the application in Entra. Users or groups are assigned to a role explicitly. The token carries the role value, and nothing else.	PREFERRED for new integrations. The token stays small regardless of group count, the assignment is explicit and readable, and it is a clean object for the ACC-17 annual application review.

Strategy	How it works	Assessment
Filtered group claims	Emit only the groups assigned to this application, or only groups matching a naming pattern such as APP--.	The right answer where the application insists on group claims. Requires a naming convention that filtering can key on (ACC-02) — which means the group names must be decided before the application is configured, not after.
All groups, unfiltered	The default. Every group the user is in, as object IDs.	NOT PERMITTED for a new integration. It is the configuration that produces the failure above, and it discloses the organization's entire group structure to a third party on every sign-in.
Group names rather than IDs	Emit sAMAccountName or display name where the application matches on a name.	Acceptable where required, with a caution: a group name is mutable, so renaming a group breaks authorisation in the same way §5 describes for identifiers. Groups used for application authorisation are not renamed casually, and the register records which ones they are.
Graph callback for overage	The application follows the link and retrieves the group list from Microsoft Graph.	Only where the vendor documents support for it, and only after it has been demonstrated on a test account deliberately placed in more than 150 groups. Vendor claims about overage handling are tested, not accepted.

6.1 Standing rules

- Groups used for application authorisation are purpose-built for that application and named so that they can be filtered — the recommended pattern is APP--. An existing distribution list is never reused as an authorisation group: conflating mail membership with access rights means a mail request silently grants access (M365-04).
- Every authorisation group has a named owner and is an object of the ACC-17 review. A group that grants access to an application and is reviewed by nobody is the definition of a grant that becomes permanent.
- Test with an account deliberately placed in a large number of groups before go-live. It takes one test account and twenty minutes, and it is the only way to see the overage failure before a user does.

7. Provisioning and deprovisioning — and the gap when there is none

> **Federation without provisioning means the leaver process does not remove access.**
> This is the most common unrecognised hole in a federated estate, and it is worth stating in the plainest possible terms.
> ACC-01 §7 disables the organization account. That stops the person signing in THROUGH the identity provider. It does not delete, disable or even touch the account that exists inside the application. Whether that matters depends entirely on the application, and nobody checks per application at the moment somebody leaves.
> What can still work after a leaver is offboarded: a local password the user set inside the application; an invitation the vendor sent to a personal address; an API or personal access token the user generated; a mobile app holding a long-lived session; and any account the application created that the organization has no inventory of.
> Most organizations do not know how large this gap is. The register (§10) and the first ACC-17 application review are how the size is established, and the honest expectation is that the first pass finds accounts in applications nobody has thought about in two years.

Provisioning model	At joiner	At leaver	Residual risk
SCIM 2.0 (target state)	The account is created in the application automatically when the person enters the assigned group or role.	The account is DEACTIVATED automatically when the organization account is disabled or the assignment is removed.	Low — but only while the SCIM credential is valid. See below.
Just-in-time provisioning from the assertion	The account is created on first successful sign-in, from the claims.	Nothing happens. The account remains, dormant but present, and any local credential still works.	Medium. A named manual step is required on the leaver checklist.
Manual, by the vendor or by IT	Somebody creates it on request.	Somebody must remember to remove it.	High. This is the model that produces forgotten accounts, and in many estates it is still the model for most applications.
None — local credentials	The user self-registers, often with an address the organization never sees.	Nothing. The organization may not even hold a list.	Highest. §3 costs this honestly.

7.1 Rules

- SCIM is asked for at intake (§2) and is a factor in the purchasing decision. Retrofitting it means reconciling accounts that already exist, which is a project rather than a configuration.
- The deprovisioning action is DEACTIVATE, not delete, wherever the application holds records the organization needs — casework, customer history, audit history.

- The SCIM bearer token is a non-human credential under ACC-08: named owner, recorded expiry, rotation date in the calendar. A token that expires silently stops provisioning, and the first symptom is a joiner who cannot get in — while the leavers it also stopped removing go unnoticed for months. Provisioning jobs in a quarantined or failed state are alerted and acted on.
- Where there is no SCIM, a named per-application step goes on the ACC-01 leaver checklist and the register carries the flag. That is worse than SCIM and enormously better than nothing. Where there is neither SCIM nor federation, the application is on the checklist twice — account and credential — and is a candidate for replacement at renewal.

---

8. Current state, target state, and migrating an application

While the organization runs two identity providers, "which one governs this application?" has to be answerable per application, in writing. A managed security partner asking whether the old provider's MFA is still in use should get an answer from a record, not from memory.

So every register entry carries two identity provider rows and a migration state: Not started, Configured in target, Piloting, Cut over, or Retired from source. The estate's progress is the count of those states, and the migration plan is a filter on the register rather than a separate document.

8.1 Migrating one application

1. RECORD THE CURRENT STATE COMPLETELY BEFORE CHANGING ANYTHING: the existing NameID source attribute and format, every claim and its exact name, the group or role mapping, the provisioning configuration, the signing certificate and its expiry, and the list of users who actually sign in. A rollback to a configuration nobody wrote down is a reconstruction, not a rollback.
2. Build the target configuration in Entra against §4, §5 and §6. Where the current NameID is an email address, this is the moment §5.2 is paid for, and the vendor conversation about re-mapping existing records happens now — not on the night.
3. Where the application supports more than one federation connection, configure both and run them in parallel — it converts the cutover from an event into a switch, and is worth asking for even when it is not offered. Where it supports only one, the cutover is atomic and the rollback is the restoration of the old provider's connection: TESTED, with the metadata, certificate and claim mapping held ready and confirmed still valid, not assumed to be a matter of pasting a URL back.
4. Pilot with named real users drawn from every population that uses the application: one who is not in IT, one on a personal or unmanaged device (DEV-07), one temporary worker on a second account, and one person who is in a great many groups (§6).
5. Run the pilot for a stated period with a named contact and a stated back-out trigger — the specific observation that ends the pilot rather than a general sense that it is going badly.
6. Cut over inside a maintenance window under GOV-04, with a change record, a named organization approver, and a communication that tells people what to do if it does not work for them.
7. Verify with a real sign-in from each population before the window closes. The engineer's own account is not a verification (§4.1). Keep the source configuration in place but disabled for 30 days — deleting the rollback path on the night converts a five-minute recovery into a rebuild under pressure.
8. Record the cutover under GOV-04 and update the register: migration state, new claim mapping, the Appendix B worksheet, and anything the vendor did on their side.

The rollback question that must be answered before, not after

Establish, in writing from the vendor, what the application does when the identifier changes. Some applications rebind an existing record to the new NameID on first sign-in; some create a duplicate; some refuse the sign-in outright.

This matters because it determines whether the rollback still works. If the application has already rebound its records to the new identifier, restoring the old identity provider does not restore the old state — the users are now keyed to a value the old provider does not send, and the rollback fails silently at the second step.

Where the vendor cannot answer this question, the answer is found on a test instance before the cutover is scheduled. Where there is no test instance, the change is escalated as irreversible under GOV-04 §5.

9. Authentication strength and vendor MFA deadlines

Authentication requirements are applied to an application by Conditional Access at the identity provider, not by asking the vendor to enforce something. That is the whole point of federating it: ACC-03 sets what a strong authentication is, and this document is how a given application comes to require it.

A common worked example: a SaaS vendor announces it will enforce phishing-resistant multifactor authentication from a fixed date. The timeline below counts back from that date (D) and assumes about five weeks of notice.

The classic way this breaks access.

A rushed phishing-resistant rollout breaks access and leaves people stuck in an MFA setup loop. The mechanism is documented in ACC-03 §11 and is not re-derived here; the one-line summary is that the policy requiring a phishing-resistant method was in scope for the registration endpoint at which users would have registered one, so the only way to satisfy the policy was to already have satisfied it.

The rule that follows is short: ENFORCEMENT FOLLOWS REGISTRATION. It never drives it. An authentication-strength change is staged behind a pilot group, with a back-out that has been performed once in test, and it is never applied to a population that has not first been shown — from the Entra authentication-methods report, not from an assumption — to hold the method it will require.

By	What must be true	Why this gate exists
D – 26 days	The population is identified from the application’s sign-in logs — every account that actually signs in — not from the licence list and not from memory.	A licence list includes people who never sign in and excludes shared and integration access. Enforcing against the wrong list is how a population gets missed.
D – 19 days	Every account in that population holds a registered phishing-resistant method, evidenced from the Entra authentication-methods report. FIDO2 keys are physically in the hands of anyone whose device cannot support a platform method.	This is the gate most often skipped. Everything below depends on it and nothing below it can compensate for it.

By	What must be true	Why this gate exists
D – 19 to D – 9 days	The Conditional Access policy runs in report-only against the population, and the report-only results are read.	Report-only tells you who would have been blocked. The absence of complaints during report-only tells you nothing, because nothing was enforced (M365-21 §5).
D – 7 days	A named pilot group is enforced, with a named contact, a stated back-out trigger, and a back-out that has been performed once so that its duration is known.	A back-out whose duration is unknown cannot be used under pressure, because nobody can say whether it will finish before the business opens.
D – 7 to D – 2 days	Full enforcement, in waves, with the service desk briefed and holding a written recovery path for a user who is stuck.	Tier 1 will receive these calls. A desk that has not been told what changed diagnoses it as an ordinary MFA fault.
D	Nothing happens. The deadline is met by a change made a week earlier.	This is the objective. The day itself should be uneventful.

> **The deadline is met by starting early, not by cutting over on the day**
>
> Cutting over on the deadline leaves no time to back out and still comply. Cutting over a week early leaves a week — which is the difference between an incident and an inconvenience.
>
> The asymmetry is worth stating: missing the deadline costs the organization access to that application. A rushed authentication-strength change costs it access to that application AND to everything else in scope of the policy, at a moment when nobody can sign in to fix it.
>
> And a caution about this document's own timetable. If the population above is not identified within the first week, the schedule is no longer available. The correct response at that point is to ask the vendor for an extension, not to compress the gates — compressing the gates is exactly what produces the setup loop.

The same pattern applies to any application-level authentication change: identify the population from real sign-ins, prove registration, run report-only, pilot with a tested back-out, enforce in waves, and record it as a change under GOV-04.

---

10. The application register

One register, holding one row per application. It is the input to the ACC-17 annual application review, to the ACC-01 leaver checklist, and to GOV-04 scheduling — which means it earns its keep three times over.

Field	Note
Application name, and what it is for	In words a non-specialist would recognise.
Business owner / IT owner	Named people (§2).
User population and approximate count	Drives the review packet under ACC-17 §4.

Field	Note
Protocol	SAML 2.0 / OIDC / SCIM alongside / directory-integrated / none.
Current IdP → Target IdP	For example, Okta → Entra ID, with the migration state (§8).
NameID source and format	FLAGGED where it is an email address or a UPN (§5.2).
Claim deviations from §4	With the reason. Silence here means the standard set.
Group or role strategy	App roles / filtered groups / other, with the group naming pattern.
Provisioning	SCIM / JIT / manual / none — and the leaver action that follows.
Authentication strength required	And any external deadline driving it (§9).
Data classes held	Per M365-15.
Contract renewal date	The date that forces the annual conversation.
Certificate expiry	Federation certificates expire and take the application down when they do. Diarised as a change under GOV-04.
Last reviewed	By ACC-17 §2.

If the register does not exist yet, the first pass is the interesting part

The first task on approval is to build it from three sources: the legacy identity provider's connector list, the Entra enterprise application list, and the contracts held by departments.

Those three lists will not agree. Expect applications in the legacy provider that nobody can name an owner for, contracted applications with no federation at all, and Entra enterprise applications created by consent that nobody requested.

The disagreements are the finding, not an obstacle to producing the register. They are reported to Tier 4 as part of the first ACC-17 annual application review.

11. Service levels

Activity	Commitment (per GOV-06)
Intake reviewed and a protocol recommendation returned	P3 — 5 coverage days from a complete intake (§2).
Incomplete intake	Returned within 2 coverage days naming what is missing, not held silently.
Federation configured for a straightforward SAML or OIDC application	10 coverage days from a complete intake and vendor metadata.
SCIM provisioning configured and verified	A further 5 coverage days. Reconciling pre-existing accounts is scoped separately.
Migration of an existing application between identity providers	Scheduled work under GOV-04. Not an on-demand request.

Activity	Commitment (per GOV-06)
Authentication-strength change on an application	Never same-day. §9 gates apply regardless of the deadline driving it.
Federation broken in production	P1 — this is an outage for everybody who uses that application.
Certificate expiry approaching	Diarised 60 days ahead as a normal change. An expired federation certificate is an avoidable P1.

12. Records

Record	Held in	Retention
Application register (§10)	IT register	Permanent — it outlives every individual application
Completed intake form (Appendix A)	Ticket + register entry	Life of the application + 3 years
Claim mapping worksheet (Appendix B)	Attached to the register entry	Life of the application, superseded versions kept 3 years
Cutover records, including the tested back-out	GOV-04 change log	7 years
Tier 4 decisions permitting a local-credential application or an email NameID	Tier 4 record	Permanent
Vendor security review and contract reference	Contract file, referenced from the register	Life of the contract + 7 years
Authentication-strength rollout evidence, including report-only results	Project record	3 years

13. Related documents

ID	Title	Relationship
ACC-03	MFA Enrollment, Reset & Account Recovery	§9 — what a strong authentication is, and §11 there is the setup-loop mechanism this document must not repeat.
ACC-07	Privileged & Administrative Account Standard	Administrative access to an application is privileged access, whoever federates it.
ACC-08	Service, Application & Non-Human Account Standard	The SCIM token, the API credential and the integration identity (§7).
ACC-01	Account Lifecycle	§7 leaver procedure — and §7 here is the gap in it.
ACC-02	Account Naming, UPN & Identifier Standard	Why an address is neither immutable nor non-reassignable (§5).
ACC-17	Periodic Access Review & Entitlement Recertification	The annual application review runs off the §10 register.

ID	Title	Relationship
M365-05	Email Alias & Address Change	§5. Every application keyed on email breaks on an M365-05 workflow.
M365-04	Distribution List & Dynamic Group Standard	§6 groups, and the attribute register behind §4.
M365-15	Data Classification & Handling	What may be sent as a claim.
M365-20	License Assignment & Reclamation	Per-user application licences and dormant accounts.
M365-21	Tenant Configuration Change Control	Conditional Access, authentication strengths and attribute commitments.
GOV-04	IT Change Management & Maintenance Windows	Every cutover in §8 and §9 is a change record and a window.
GOV-03	Security Incident Response	Where a federation compromise goes.
GOV-06	Service Commitments, Priority & Escalation	Supplies §11.

Appendix A — Application onboarding intake form

Submitted to Tier 3, ideally before the contract is signed. An incomplete form is returned with the missing fields named, not actioned on a best guess.

Field	Entry
Application name and vendor	
What it is for, in one sentence	Written for somebody outside the department.
Business owner	Named person, role, email. Not a department.
Who will use it	Staff / contractors / temporary workers / guests / a named list — with approximate numbers.
Data it will hold or receive	Including whether any of it is payroll, client-record or otherwise sensitive (M365-15).
Licence model and annual cost	Per user / site / consumption. Who pays.
Contract status	Signed / in negotiation / renewal date.
Federation support, in the vendor's words	SAML 2.0 / OIDC / neither. Metadata URL. Signed assertions supported?
SCIM 2.0 provisioning	Included / chargeable upgrade / not supported. If not supported, who removes leavers by hand?
Authorisation model	App roles / group claims / managed inside the application.

Field	Entry
Multifactor and authentication strength	Can it accept the strength required by ACC-03? Any external deadline (§9)?
Test instance available?	YES / NO. If no, how is anything tested before it reaches everybody?
Support model	Who does a user contact when it does not work — the vendor, the department, or the service desk?
Accessibility statement / VPAT	Requested from the vendor.
— IT USE — protocol decision (§3)	And the Tier 4 decision reference if no federation.
— IT USE — register entry created	Date, by whom.

Appendix B — SAML claim mapping worksheet

Completed for every federated application and attached to the register entry. This is the artefact whose absence makes a one-off claims meeting unrepeatable. Fill in the actual configured values, not the intended ones.

Claim as the vendor names it	Claim name / URI configured	Source attribute	Verified
Unique identifier (NameID)	Format: persistent	user.objectid	☐ Confirmed not an email address
Email address	.../claims/emailaddress	user.mail	☐ Display only — application does not key on it
User principal name	.../claims/upn	user.userprincipalname	☐
First name	.../claims/givenname	user.givenname	☐
Last name	.../claims/surname	user.surname	☐
Display name	.../claims/displayname	user.displayname	☐ Only if consumed
Employee or record ID		user.employeeid / [attribute per §4.2 open item]	☐
Groups or roles		user.assignedroles / filtered user.groups	☐ Strategy per §6 recorded below
Other (list)			☐ Reason recorded on the register

Confirmations before go-live

- ☐ Tested with a staff account, a contractor account, a temporary-worker second account and a guest — whichever populations apply.
- ☐ Tested with an account deliberately in more than 150 groups, if group claims are used (§6).

- [ ] Group strategy recorded: app roles / filtered groups / group names, and the naming pattern used.
- [ ] Provisioning model recorded, and the leaver action stated in words (§7).
- [ ] SCIM credential owner and rotation date recorded under ACC-08.
- [ ] Signing certificate expiry diarised as a change under GOV-04.
- [ ] Vendor's written answer on what happens when the identifier changes (§8.1).
- [ ] Back-out configuration captured and held, and confirmed still valid.
- [ ] Register entry created or updated, with the migration state.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.